

Présentation finale - Cybersécurisation des infrastructures

SÉCURISATION D'UNE INFRASTRUCTURE WEB & BASE DE DONNÉES

SEGMENTATION RÉSEAU – PFSense – HAProxy – DÉFENSE EN PROFONDEUR

B2CS1 - Sherine EDEL, Syrine ABDELBASSET, Lina FASSI, Mounia DJA DAOUADJI

SOMMAIRE

- Schéma global de l'architecture
- PfSense & segmentation réseau
- Serveurs web
- Base de données
- Administration & supervision
- Haute disponibilité (HAProxy)
- Démonstrations
- Problèmes rencontrés
- Conclusion

CONTEXTE & OBJECTIF

- Infrastructure Web exposée sur Internet
- Segmentation réseau stricte
- Principe du deny by default
- Haute disponibilité HAProxy
- Isolation complète de la base de données

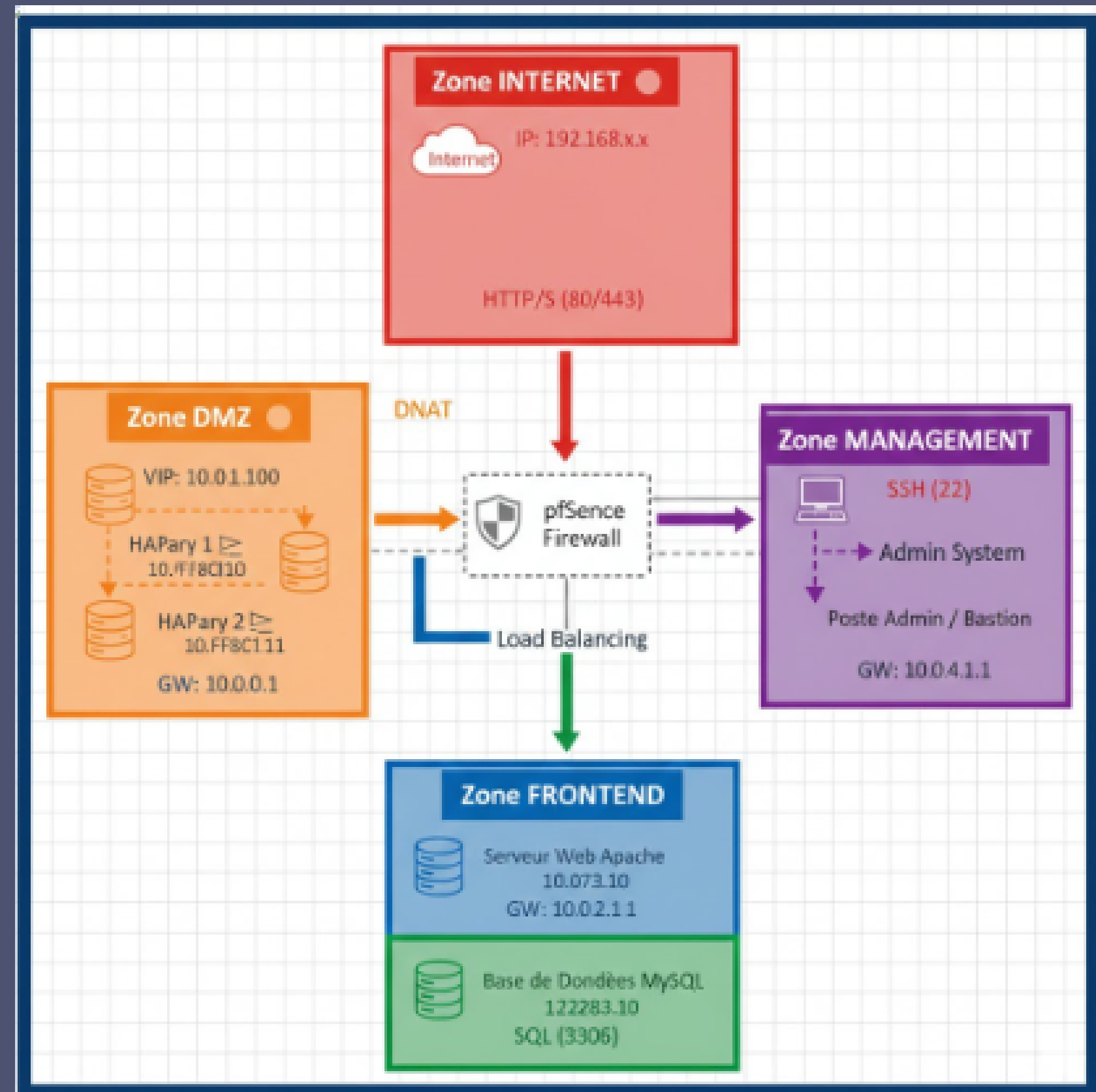
ARCHITECTURE GLOBALE

Zones colorées :

- DMZ (HAProxy)
- FRONTEND (Web)
- DATA (BDD)
- ADMIN

IP affichées sur le schéma :

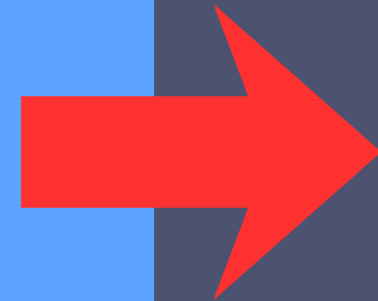
- HAProxy1 : 192.168.20.20
- HAProxy2 : 192.168.20.21
- Web1 : 192.168.10.10
- Web2 : 192.168.10.11
- BDD : 192.168.30.10
- Admin : 192.168.40.10



STRATÉGIE DE DEFENSE EN PROFONDEUR

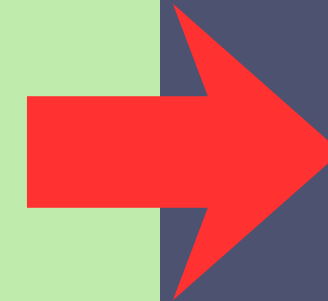
Couche 1 : Réseau

- VLAN séparés
- pfSense point central
- deny by default



Couche 2 : Système

- Hardening AlmaLinux
- Services inutiles désactivés
- SSH sécurisé



Couche 3 : Applicatif

- Permissions MySQL minimales
- Isolation BDD
- Journalisation active

PFSENSE & SEGMENTATION

Non sécurisé 192.168.140.130/interfaces_assign.php

pfSense COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Interfaces / Interface Assignments

Interface Assignments Interface Groups Wireless VLANs QinQs PPPs GREs GIFs Bridges LAGGs

Interface	Network port	
WAN	em0 (00:0c:29:56:b2:65)	
LAN	em1 (00:0c:29:56:b2:6f)	Delete
FRONTEND	em2 (00:0c:29:56:b2:79)	Delete
DATA	em3 (00:0c:29:56:b2:83)	Delete
DMZ	em4 (00:0c:29:56:b2:8d)	Delete
ADMIN	em5 (00:0c:29:56:b2:97)	Delete

Save

pfSense

COMMUNITY EDITION

System

Interfaces

Firewall

Services

VPN

Status

Diagnostics

Help

Firewall / Rules / DMZ

Floating

WAN

LAN

FRONTEND

DATA

DMZ

ADMIN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	IPv4 TCP	DMZ subnets	*	FRONTEND subnets	80 (HTTP)	*	none	Allow HAProxy -> Web Servers	
☐	✓	0/0 B	IPv4 TCP	192.168.10.0	*	192.168.20.0	3000 - 8080	*	none	communication applicative	
☐	✓	0/0 B	IPv4 TCP	192.168.10.0	*	*	80 - 443	*	none	Mises a jour	
☐	✓	0/0 B	IPv4 TCP/UDP	192.168.10.0	*	*	53 (DNS)	*	none	DNS	
☐	✗	0/0 B	IPv4 *	DMZ subnets	*	ADMIN subnets	*	*	none	bloquer DMZ -> ADMIN	

DENY BY
DEFAULT

pfSense

COMMUNITY EDITION

System

Interfaces

Firewall

Services

VPN

Status

Diagnostics

Help

Firewall / Rules / FRONTEND

Floating

WAN

LAN

FRONTEND

DATA

DMZ

ADMIN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/7 KiB	IPv4 ICMP any	FRONTEND subnets	*	*	*	*	none		
☐	✓	0/0 B	IPv4 TCP	FRONTEND subnets	*	DMZ subnets	80 (HTTP)	*	none	Allow Web Servers response to HAProxy	
☐	✓	0/0 B	IPv4 TCP	192.168.20.0	*	*	80 - 443	*	none	Accès web sortant	
☐	✓	0/0 B	IPv4 TCP	192.168.20.0	*	192.168.50.0	22 (SSH)	*	none	Gestion admin	
☐	✓	0/0 B	IPv4 TCP	192.168.20.0	*	192.168.30.0	3306	*	none	Accès base de donnée	

Flux autorisés		
Source	Destination	Port
Internet	VIP HAProxy	80
HAProxy	Serveur Web	80
Serveur Web	BDD	3306
Admin	Tous serveurs	22

MATRICE
DE FLUX

DEFENSE EN PROFONDEUR

Couche 1: Réseau → Firewall

Couche 2: Système → Hardening Almalinux

Couche 3: Applicative → Permission MySQL

SERVEUR WEB ET BDD

2 serveurs Web:

web 1: 192.168.10.10

web 2: 192.168.10.11

BDD dans DATA: 192.168.30.10.

→

Isolée

SERVEUR WEB ET BDD

```
server_BDD_01 × web × template ×  
[root@localhost ~]# ss -tuln | grep 3306  
tcp    LISTEN 0      80      0.0.0.0:3306      0.0.0.0:*  
[root@localhost ~]#
```

ss -tuln sur BDD

Test accès depuis DMZ
(HAProxy)

```
[root@localhost ~]# ssh root@192.168.40.10  
ssh: connect to host 192.168.40.10 port 22: Connection timed out  
[root@localhost ~]# _
```

HAPROXY

2 HAProxy:

192.168.20.20

192.168.20.21

Ils sont placé en DMZ

Ils distribuent le trafic vers

- web1
- web2

HAUTE DISPONIBILITE

```
[root@localhost ~]# systemctl status keepalived
• keepalived.service - LVS and VRRP High Availability Monitor
   Loaded: loaded (/usr/lib/systemd/system/keepalived.service; enabled; vendor preset: disabled)
   Active: active (running) since Sun 2026-02-15 22:00:13 EST; 2h 42min ago
 Main PID: 1829 (keepalived)
    Tasks: 2 (limit: 10936)
   Memory: 1.6M
    CGroup: /system.slice/keepalived.service
            └─1829 /usr/sbin/keepalived -D
              └─1830 /usr/sbin/keepalived -D

févr. 16 00:37:59 localhost.localdomain Keepalived_vrrp[1830]: Sending gratuitous ARP on ens224 for 192.168.10.4
févr. 16 00:37:59 localhost.localdomain Keepalived_vrrp[1830]: Sending gratuitous ARP on ens224 for 192.168.10.4
févr. 16 00:37:59 localhost.localdomain Keepalived_vrrp[1830]: Sending gratuitous ARP on ens224 for 192.168.10.4
févr. 16 00:37:59 localhost.localdomain Keepalived_vrrp[1830]: Sending gratuitous ARP on ens224 for 192.168.10.4
févr. 16 00:38:04 localhost.localdomain Keepalived_vrrp[1830]: (VI_1) Sending/queueing gratuitous ARPs on ens224 for 192.168.10.4
févr. 16 00:38:04 localhost.localdomain Keepalived_vrrp[1830]: Sending gratuitous ARP on ens224 for 192.168.10.4
févr. 16 00:38:04 localhost.localdomain Keepalived_vrrp[1830]: Sending gratuitous ARP on ens224 for 192.168.10.4
févr. 16 00:38:04 localhost.localdomain Keepalived_vrrp[1830]: Sending gratuitous ARP on ens224 for 192.168.10.4
févr. 16 00:38:04 localhost.localdomain Keepalived_vrrp[1830]: Sending gratuitous ARP on ens224 for 192.168.10.4
```

STATUS KEEPALIVED

VIP

```
[root@localhost ~]# ip a | grep 192.168.10.4
    inet 192.168.10.4/24 scope global secondary ens224
[root@localhost ~]# _
```

Le service reste accessible sans interruption visible pour l'utilisateur.

HAUTE DISPONIBILITE



Le service reste accessible sans interruption visible pour l'utilisateur.

DEMONSTRATION PREVUE

- Extinction HAProxy 1 → service OK

- Tentative accès BDD depuis DMZ → échec

- Tentative SSH mauvais réseau → bloqué

Nous allons démontrer que la segmentation fonctionne réellement.

ADMIN

Le réseau ADMIN est un réseau totalement séparé de l'infrastructure, il permet:

- L'administration en SSH
- Le diagnostic des problèmes
- Les tests réseaux

PROBLEMES RENCONTRES

Problème principal

- L'accès final au site depuis le réseau ADMIN ne fonctionne pas
- Impossible de ping google.com depuis HAProxy
- NAT fonctionne avec 192.168.10.10 mais pas avec 192.168.10.4

Ce que nous avons validé

- HAProxy communiquent entre eux
- Les serveurs web accèdent à la BDD
- pfSense accède au site (curl OK)
- Les règles firewall sont cohérentes

Hypothèses techniques

- Règle implicite manquante sur LAN
- Problème de routage retour entre FRONTEND & DMZ
- Problème ARP entre pfSense et HAProxy
- Mauvais NAT outbound

Ce que cela nous a appris

- Comprendre le routage inter-zones
- Maîtriser le retour de flux (stateful firewall)
- Analyser couche 2 et couche 3
- Tester méthodiquement chaque maillon

CONCLUSION

Appliqué d'une vraie segmentation réseau

Les flux sont strictement contrôlés

La haute disponibilité garantit la continuité du service

L'approche STRIDE nous a permis d'identifier et prioriser les risques